

c.AAA (Authentication, Authorization, Accounting): Three core functions, AAA in Networking & Security, AAA Deployment Models.

Task 1.

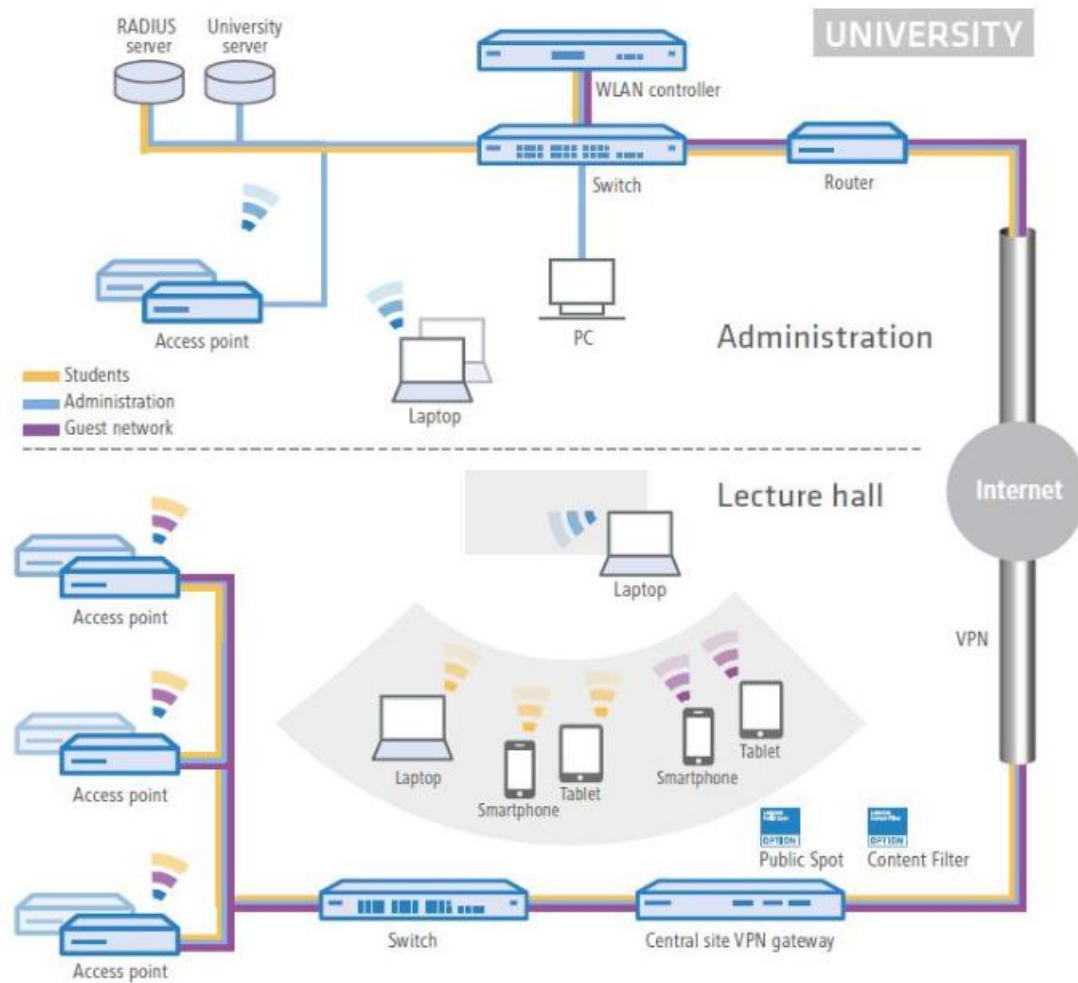
Create a table comparing Authentication, Authorization, and Accounting (AAA) by listing at least two real-world examples of each function from popular apps like Instagram, Zomato, or Paytm.

AAA Function	Meaning	Real-world Example 1 – Instagram	Real-world Example 2 – Zomato/Paytm
Authentication	Verifies who the user is	Logging into Instagram using username/password, OTP, or biometric authentication	Logging into Zomato/Paytm using a mobile number and OTP
Authorization	Determines what the authenticated user is allowed to do	A normal user can post and comment, while an account administrator may have additional management permissions	A Zomato customer can place orders, while a restaurant partner can manage menus and orders
Accounting	Records what the user did, when, and sometimes from where	Recording login activity, sessions, and security-related account events	Recording orders, payments, refunds, login sessions, and transaction timestamps

Task 2.

**Draw a simple network diagram showing how AAA is used to secure access to a WiFi network in a college campus, labeling where authentication, authorization, and accounting take place.

Hint: Include devices like user laptops, access points, AAA server, and the internet gateway.**



How it works

1. **Authentication:** Student enters college username/password. The AP forwards the authentication request to the AAA/RADIUS server.
2. **Authorization:** AAA server checks the student's account and determines what network access is permitted, such as student VLAN or staff VLAN.
3. **Accounting:** AAA server records information such as login time, logout time, username, and session information.
4. If access is approved, traffic goes through the Internet Gateway to the Internet.

Task 3.

Explain the difference between centralized and distributed AAA deployment models by describing how each would work in a scenario where multiple Flipkart warehouses need secure network access.

Feature	Centralized AAA	Distributed AAA
AAA servers	One central AAA system/server	Each warehouse has its own local AAA server/system
Authentication	Requests from all warehouses go to central AAA	Each warehouse can authenticate users locally
Management	Policies managed from one location	Policies managed separately at each warehouse
Failure impact	Central server/network failure can affect multiple warehouses	Failure at one warehouse generally affects only that warehouse
Consistency	Easier to maintain the same policies everywhere	Policies can become different between warehouses
Example	Ahmedabad, Mumbai and Delhi warehouses all authenticate against one central RADIUS server	Each warehouse has its own RADIUS server for local authentication

Task 4.

Pick any one AAA deployment model and list three advantages and two disadvantages of using it for a large-scale app like BookMyShow.

AAA Model for BookMyShow

Selected model: Centralized AAA

For a large application such as BookMyShow, a centralized AAA approach can use centrally managed identity and access policies across its application infrastructure.

Advantages

1. Centralized management

Administrators can manage users, roles, and access policies from a common system.

2. Consistent security policies

The same authentication and authorization rules can be applied across different application services.

3. Centralized auditing

Security and user activity logs can be collected in a central location, making monitoring and auditing easier.

Disadvantages

1. Dependency on central infrastructure

If the central AAA service becomes unavailable, authentication or access to dependent services may be affected unless redundancy is provided.

2. Scalability requirements

A very large application needs highly scalable and redundant AAA infrastructure to handle large numbers of authentication requests.

Task 5.

Use ChatGPT or another AI tool to generate a sample AAA policy for a Zomato-like app, specifying what actions are authenticated, which roles are authorized for each action, and what accounting logs should be kept. Paste the generated policy and highlight one thing you would change to make it more secure

Action	Authentication Required?	Authorized Role	Accounting / Logs
User login	Yes	Customer, Restaurant Partner, Delivery Partner, Admin	Login time, user ID, IP/device information, success/failure
Place food order	Yes	Customer	User ID, restaurant, order ID, timestamp, order status
Cancel order	Yes	Customer, Restaurant Partner, Admin according to defined conditions	User ID, order ID, cancellation time and reason
Manage restaurant menu	Yes	Restaurant Partner	Restaurant ID, user ID, menu changes, timestamp
Accept/assign delivery	Yes	Delivery Partner	Partner ID, order ID, assignment time, status changes
Process/refund payment	Yes	Authorized payment/admin services	Transaction ID, amount, timestamp, result
View customer data	Yes	Authorized support/admin roles	User ID, employee/service ID, accessed records, timestamp
Change security settings	Yes	Account owner/Admin	User ID, change made, timestamp, device/IP

ZOMATO-LIKE AAA POLICY

1. Authentication - All users must authenticate before accessing protected services. - Sensitive operations require re-authentication or an additional verification factor where appropriate. - Failed authentication attempts must be recorded.

2. Authorization - Customers may manage their own profiles and orders. - Restaurant partners may manage their own restaurant information, menus and incoming orders. - Delivery partners may access delivery information assigned to them. - Administrators may access administrative functions according to their assigned privileges. - Users must not access resources belonging to other users or partners.

3. Accounting - Record successful and failed login attempts. - Record important account and permission changes. - Record order creation, cancellation and status changes. - Record payment and refund events. - Record administrative access to sensitive information. - Logs should include timestamps, relevant user/service IDs, action performed and result.

4. Log Protection - Security logs should be protected from unauthorized modification. - Access to logs should be restricted to authorized personnel. - Logs should have an appropriate retention period based on operational, security and legal requirements.

One security improvement I would make

I would require multi-factor authentication (MFA) for administrative accounts and other high-risk operations.